

RAPPORT D'AUDIT DE SÉCURITÉ ET PLAN DE REMÉDIATION

Projet : TRACE (Traçabilité, Réemploi et Affectation Circulaire des Équipements)

Date de l'audit : 22 Mai 2026

Périmètre : Code source Front-end (Vanilla JS), Back-end (PostgreSQL/PostgREST), Scripts de déploiement (Debian postinst).

1. SYNTHÈSE EXÉCUTIVE

L'audit du code source de l'application TRACE révèle une architecture moderne s'appuyant sur des bases solides (chiffrement des mots de passe en Bcrypt, isolation des tokens JWT en HttpOnly, mesures anti-bruteforce via Fail2Ban).

Néanmoins, le système présente **deux vulnérabilités critiques** et **des failles majeures** liées à la gestion des privilèges en base de données et à l'initialisation du déploiement. Ces failles permettent actuellement à un attaquant ou un utilisateur interne malveillant de prendre le contrôle total de l'application, d'altérer l'inventaire et d'effacer les journaux d'audit.

Une remédiation immédiate est requise avant toute mise en production.

2. CONSTATS DÉTAILLÉS DES VULNÉRABILITÉS

VULNÉRABILITÉS CRITIQUES (CVSS 9.0 - 10.0)

C-01 : Identifiants administrateur par défaut codés en dur

- **Composant :** Script d'installation (postinst)
- **Description :** Le script de déploiement initialise le compte admin@gouv.fr avec le mot de passe statique admin. C'est une faille de type CWE-1188.
- **Risque :** N'importe quel agent ou attaquant identifiant l'URL de l'application peut se connecter avec les privilèges maximums.

C-02 : Élévation de privilèges SQL (Contournement du RBAC Front-End)

- **Composant :** Schéma de base de données (schema.sql)
- **Description :** La commande GRANT ALL ON ALL TABLES IN SCHEMA public TO agent, administrateur; octroie tous les droits (DELETE, TRUNCATE) au rôle agent.
- **Risque :** Bien que l'interface web (UI) masque le bouton "Supprimer" aux agents, un agent peut forger une requête API directe vers PostgREST pour détruire l'intégralité du parc mobilier ou des comptes utilisateurs.

● VULNÉRABILITÉS MAJEURES (CVSS 7.0 - 8.9)

M-01 : Répudiation et Falsification du Journal d'Audit

- **Composant** : Schéma de base de données (schema.sql)
- **Description** : Conséquence du GRANT ALL, le rôle agent possède les droits d'écriture et de suppression sur la table audit_logs.
- **Risque** : Un utilisateur malveillant peut exécuter une action destructrice puis effacer les lignes correspondantes dans le journal d'audit pour masquer ses traces.

● VULNÉRABILITÉS MODÉRÉES (CVSS 4.0 - 6.9)

Mod-01 : Certificat SSL Auto-signé

- **Composant** : Script d'installation (postinst)
- **Description** : Génération d'un certificat auto-signé trace.crt.
- **Risque** : Provoque des alertes de sécurité dans les navigateurs, habituant les agents à ignorer les avertissements (risque d'attaque Man-in-the-Middle).

3. PLAN DE REMÉDIATION ET CORRECTIONS CODE

Action 1 : Sécurisation du compte Administrateur initial (Fix C-01)

Modifier le fichier postinst pour forcer l'administrateur système à saisir un mot de passe lors de l'installation du paquet Debian.

Dans postinst :

```
# Remplacer : ADMIN_PASS="admin" par :
echo "Veuillez définir le mot de passe pour le compte administrateur (admin@gouv.fr) :"
read -s -p "Mot de passe : " ADMIN_PASS
echo ""
# Vérification de complexité (optionnelle mais recommandée)
if [ ${#ADMIN_PASS} -lt 8 ]; then
    echo "Erreur : Le mot de passe doit faire au moins 8 caractères."
    exit 1
fi
```

Action 2 : Application du principe de Moindre Privilège SQL (Fix C-02)

Revoir intégralement la matrice des permissions dans PostgreSQL pour garantir l'intégrité des données au niveau du moteur SQL.

Dans schema.sql (Section "Vues et Permissions") :

-- REMPLACER LE "GRANT ALL" PAR :

```
-- Droits de l'Agent (Consultation, Ajout, Modification - MAIS PAS DE SUPPRESSION)
GRANT SELECT, INSERT, UPDATE ON TABLE public.mobiliers TO agent;
GRANT SELECT ON TABLE public.gabarits, public.lieux, public.structures TO agent;
GRANT USAGE, SELECT ON SEQUENCE public.seq_mobilier_id TO agent;

-- Droits de l'Administrateur (Tous les droits métier)
GRANT SELECT, INSERT, UPDATE, DELETE ON ALL TABLES IN SCHEMA public TO administrateur;
GRANT ALL ON ALL SEQUENCES IN SCHEMA public TO administrateur;

-- Sécurité stricte sur l'Audit (Personne ne peut supprimer ou modifier l'historique)
REVOKE ALL ON TABLE public.audit_logs FROM PUBLIC, agent, administrateur, lecteur;
GRANT SELECT ON TABLE public.audit_logs TO administrateur;
-- (Les INSERT sont gérés par les Triggers qui s'exécutent en SECURITY DEFINER)
```

Action 3 : Verrouillage cryptographique du Journal d'Audit (Fix M-01)

Même avec de bons GRANT, il est recommandé d'ajouter une règle de sécurité absolue au niveau du moteur de base de données pour empêcher toute altération de l'historique.

Dans schema.sql :

```
-- Règle d'immutabilité de l'audit
CREATE RULE no_update_audit AS ON UPDATE TO public.audit_logs DO INSTEAD NOTHING;
CREATE RULE no_delete_audit AS ON DELETE TO public.audit_logs DO INSTEAD NOTHING;
CREATE RULE no_truncate_audit AS ON TRUNCATE TO public.audit_logs DO INSTEAD
NOTHING;
```

Action 4 : Infrastructure TLS (Fix Mod-01)

Certificats SSL : Intégrer un processus d'enrôlement Let's Encrypt (Certbot) dans le script postinst (si le serveur est exposé sur internet) ou automatiser le déploiement des certificats de l'Autorité de Certification interne du Ministère pour remplacer les certificats auto-signés.

Conclusion : L'application de ces correctifs garantira l'étanchéité des rôles utilisateurs et l'opposabilité légale du journal d'audit. L'architecture PostgREST deviendra ainsi parfaitement robuste contre les tentatives d'accès direct à l'API.